

Narrativa Explicativa del Kit de Diagnóstico COSO-Ciber

Contexto, Fundamentos y Lógica del Instrumento

Encuesta sobre Indicadores y Métricas de Ciberseguridad en el Marco COSO

"El ciberriesgo ha dejado de ser un problema del Departamento de TI. Es el riesgo estratégico del siglo XXI, y los marcos que se diseñaron para gestionar el riesgo empresarial tienen —al fin— algo relevante que decir sobre él."

— Paráfrasis de la posición del COSO ERM 2017

1. Por Qué Esta Encuesta, Por Qué Ahora

El año 2025 marcó un punto de inflexión en el paisaje del ciberriesgo europeo. La Directiva NIS2 entró en plena vigencia, imponiendo obligaciones de gestión del riesgo y notificación de incidentes a más de 160.000 entidades en la UE; DORA comenzó a aplicarse al sector financiero desde enero de 2025; y el CNPIC consolidó la nueva Ley de Infraestructuras Críticas en el contexto español. Al mismo tiempo, los ataques con inteligencia artificial como vector de automatización adversarial redujeron el *time-to-exploit* a rangos de horas, y los primeros estándares de criptografía post-cuántica del NIST (ML-KEM, ML-DSA, SLH-DSA) establecieron la agenda de migración para la próxima década.

En este contexto, el Committee of Sponsoring Organizations of the Treadway Commission (COSO) actualizó en 2026 sus principios de gobierno corporativo (*Corporate Governance Framework*) incorporando explícitamente la supervisión del ciberriesgo como responsabilidad ineludible del consejo de administración. El Principio 8 del CGF 2026 establece que el consejo debe *"comprender y supervisar la exposición al ciberriesgo, asegurando que la alta dirección dispone de marcos, recursos y métricas adecuados para identificar, evaluar y responder a las amenazas cibernéticas"*.

Y sin embargo, el diagnóstico empírico sobre el grado de adopción real de estos principios —especialmente en España— sigue siendo fragmentario, heterogéneo y mayoritariamente basado en percepciones más que en datos objetivos. Esta encuesta pretende llenar ese vacío.

2. La Lógica del Marco COSO Aplicada al Ciberriesgo

El COSO no es un marco de ciberseguridad. Es algo más ambicioso: es una arquitectura de pensamiento sobre la relación entre el gobierno, el riesgo y el control en las organizaciones. Su utilidad para el ciberriesgo reside precisamente en que eleva el debate por encima del nivel técnico —donde el léxico de los firewalls, los parches y los CVEs tiende a aislar el ciberriesgo del resto de la conversación empresarial— y lo sitúa en el plano estratégico donde genuinamente reside.

Los cinco componentes del **COSO ERM 2017** se traducen, en el contexto ciber, del siguiente modo:

Componente I — Gobierno y Cultura

El *tono desde la cúspide* en ciberseguridad no es una metáfora pedagógica: es una variable empíricamente asociada a la madurez del programa ciber. Las organizaciones cuyos consejos revisan regularmente el ciberriesgo, cuentan con consejeros con competencias digitales y han formalizado la línea de reporte del CISO, sistemáticamente presentan mejores indicadores operativos (MTTD, MTTR, cobertura de MFA, resiliencia). Esto ha sido documentado por Deloitte (2025), el FAIR Institute (2025) y el propio COSO en su publicación "*Managing Cyber Risk in a Digital Age*" (en colaboración con Deloitte, 2020).

Componente II — Estrategia y Apetito de Riesgo

La integración del ciberriesgo en la estrategia empresarial —más allá del ritual del "capítulo de riesgos" en el plan estratégico— implica que las decisiones de expansión a nuevos mercados, las adquisiciones, la adopción de arquitecturas cloud o la incorporación de tecnologías emergentes (IA, IoT, blockchain) se sometan a evaluación ciber antes de ser aprobadas. Y, sobre todo, implica que el **apetito de riesgo ciber** esté cuantificado financieramente: ¿cuánta pérdida esperada anual es la organización dispuesta a tolerar? Sin esta cifra, el apetito de riesgo es, en la práctica, infinito.

La metodología FAIR (Factor Analysis of Information Risk) —recomendada explícitamente por COSO y NIST en sus guías conjuntas— proporciona el lenguaje compartido entre el CISO y el CFO para responder esta pregunta en euros, no en semáforos de colores.

Componente III — Desempeño

Este es el corazón del sistema de medición. Los **indicadores de desempeño ciber** son la materia prima de toda gestión basada en evidencia. No se pueden tomar decisiones racionales sobre inversión en ciberseguridad sin responder estas preguntas: ¿Cuánto tardamos en detectar un incidente (MTTD)? ¿Cuánto en contenerlo (MTTR)? ¿Qué porcentaje de vulnerabilidades críticas llevan más de 30 días sin parchear? ¿Qué cobertura tenemos de MFA en las cuentas privilegiadas? ¿Con qué frecuencia verificamos que los backups son recuperables?

La encuesta dedica el Bloque III —el más extenso— a estas métricas operativas, que también son los indicadores que más directamente se vinculan a los requerimientos regulatorios del ENS, la NIS2 y DORA.

Componente IV — Revisión y Mejora

Los programas de ciberseguridad que no se evalúan independientemente tienden a la autocomplacencia. Las auditorías internas, los pentests externos, los ejercicios de red team y los tabletop exercises son los mecanismos de retroalimentación que permiten calibrar la diferencia entre lo que se documenta y lo que funciona. La frecuencia y calidad de estas evaluaciones es uno de los mejores predictores de la madurez general del programa.

Componente V — Información, Comunicación y Reporte

La *última milla* del sistema de gobierno del ciberriesgo. El mejor programa técnico de ciberseguridad produce cero valor estratégico si la información que llega al consejo es incomprensible, incompleta o

llega demasiado tarde. Los consejos necesitan cuadros de mando con métricas financieras (no solo técnicas), comparativas con el apetito de riesgo aprobado, y protocolos de escalado claros ante incidentes significativos.

3. El Contexto Español: Singularidades y Desafíos

España presenta un perfil singular en el panorama europeo de ciberseguridad:

Fortalezas estructurales:

- El **Centro Criptológico Nacional (CCN)** y el **INCIBE** conforman un ecosistema de apoyo al sector público y privado sin parangón en muchos países de la UE. El CCN-CERT es reconocido internacionalmente por su producción de guías técnicas de referencia.
- El **Esquema Nacional de Seguridad (ENS)** proporciona a las administraciones públicas un marco de certificación de seguridad maduro y consolidado, actualmente en su versión RD 311/2022.
- La **Estrategia de Ciberseguridad Nacional 2025-2030** establece objetivos ambiciosos de capacitación, coordinación e inversión pública en ciberseguridad.

Desafíos persistentes:

- El **tejido empresarial español** es predominantemente de PYMES, que representan el 99,8% de las empresas y el 65% del empleo. Para la mayoría de ellas, la NIS2 es una novedad normativa con escasos recursos para implementar sus requisitos de gobernanza y reporte.
- La **brecha de talento** es uno de los desafíos más agudos: el déficit de profesionales de ciberseguridad en España se estima en más de 25.000 profesionales para 2026, según las proyecciones del INCIBE y el ISMS Forum España.
- La **madurez del reporte al consejo** sigue siendo una asignatura pendiente: según los datos del ISMS Forum (2025), menos del 35% de los consejos españoles de empresas no cotizadas reciben reportes específicos y regulares de ciberriesgo.

4. La Perspectiva Comparada: España en el Mapa Global

Esta encuesta adopta una perspectiva explícitamente comparada. Los datos obtenidos se contextualizarán en los siguientes benchmarks:

Referente	Métricas clave	Periodicidad
ENISA NIS Investments (UE)	Inversión ciber/IT, madurez de controles por sector, brechas de implementación	Anual
IBM Cost of a Data Breach (global)	MTTD/MTTR, coste por brecha, vectores de ataque, impacto del AI en detección	Anual
ISACA CMMI Cybersecurity (global/Europa)	Niveles de madurez por dominio	Anual
FAIR Institute State of CRM (global)	Adopción de cuantificación financiera del ciberriesgo	Anual
Deloitte Global Future of Cyber	Tendencias estratégicas, gobierno corporativo ciber	Anual
ISMS Forum Spain	Inversión, talento, regulación en España	Anual
Gartner CISO Effectiveness	Eficacia y evolución del rol del CISO	Anual

5. Sobre el Tono y el Estilo del Instrumento

Un manual de metodología podría demandar que las opciones de respuesta sean asépticas, neutras, desprovistas de todo rasgo expresivo. Esta encuesta ha optado conscientemente por un camino diferente.

Las organizaciones que invierten 45–60 minutos en responder un instrumento de estas características merecen un interlocutor que comprende la complejidad —y las contradicciones— de gestionar la ciberseguridad en el mundo real. Donde la burocracia de aprobación supera con creces la ventana de explotación de una vulnerabilidad. Donde el presupuesto para ciberseguridad se discute en noviembre y el ransomware no respeta los calendarios fiscales. Donde el consejo pregunta "¿estamos seguros?" y el CISO sabe que la respuesta honesta es "depende de qué umbral consideren aceptable".

Las opciones marcadas con una nota irónica no degradan el rigor analítico del instrumento —todas las respuestas son codificadas y analizadas con el mismo tratamiento estadístico— pero sí invitan al encuestado a identificarse en ellas, a reconocer sin vergüenza la brecha entre el ideal del estándar y la realidad de la organización. Y en ese reconocimiento, hay más valor diagnóstico que en la respuesta políticamente correcta.

6. Del Diagnóstico a la Acción

El Índice Global de Madurez (IGM) que genera este instrumento no es un fin en sí mismo. Es el punto de partida para:

1. Benchmarking sectorial: ¿Dónde se sitúa la organización respecto a sus pares del sector en España y la UE?
2. Priorización de inversiones: Las 14 preguntas IAT señalan los controles COSO con mayor potencial de reducción de riesgo en el corto plazo.
3. Comunicación al consejo: El IGM y sus componentes proporcionan el lenguaje ejecutivo que el consejo necesita para supervisar el ciberriesgo sin perderse en los detalles técnicos.
4. Cuantificación del ROI: La Plantilla Excel (Documento e) permite calcular el ROSI de los controles implementados y proyectar el impacto financiero de las inversiones propuestas.
5. Hoja de ruta de mejora: El análisis de brechas entre el IGM actual y el IGM objetivo orienta el plan de mejora con acciones concretas, responsables y métricas de seguimiento.

7. Glosario de Términos Clave

Término	Definición
ALE (Annual Loss Expectancy)	Pérdida financiera esperada anual debida a un riesgo específico: $ALE = SLE \times ARO$
ARO (Annual Rate of Occurrence)	Frecuencia estimada de ocurrencia de un evento de pérdida en un año
BCP (Business Continuity Plan)	Plan de Continuidad de Negocio: mantiene las operaciones críticas durante y tras una interrupción
CIEM (Cloud Infrastructure Entitlement Management)	Gestión de permisos e identidades en entornos cloud a escala
CSPM (Cloud Security Posture Management)	Detección y corrección continua de misconfiguraciones de seguridad en entornos cloud
CVE (Common Vulnerabilities and Exposures)	Identificador estandarizado de vulnerabilidades de seguridad conocidas
CVSS (Common Vulnerability Scoring System)	Sistema de puntuación de severidad de vulnerabilidades (0–10)
DORA (Digital Operational Resilience Act)	Reglamento UE 2022/2554 de resiliencia operativa digital para el sector financiero
DRP (Disaster Recovery Plan)	Plan de Recuperación ante Desastres: restaura los sistemas TI tras una interrupción mayor
ENS (Esquema Nacional de Seguridad)	Marco de certificación de seguridad para la Administración Pública española (RD 311/2022)
EPSS (Exploit Prediction Scoring System)	Probabilidad estimada de explotación activa de una vulnerabilidad en los próximos 30 días
ERM (Enterprise Risk Management)	Gestión de Riesgo Empresarial: enfoque integrado para identificar, evaluar y gestionar todos los riesgos
FAIR (Factor Analysis of Information Risk)	Metodología de cuantificación financiera del ciberriesgo; estándar ANSI/OpenFAIR
GRC (Governance, Risk & Compliance)	Plataforma o enfoque integrado de gobierno, riesgo y cumplimiento
IAM (Identity & Access Management)	Gestión de identidades y acceso: quién puede acceder a qué
IGM (Índice Global de Madurez)	Puntuación compuesta (1–5) del nivel de madurez del programa COSO-Ciber
IRP (Incident Response Plan)	Plan de Respuesta a Incidentes: procedimientos de detección, contención y recuperación
KRI (Key Risk Indicator)	Indicador Clave de Riesgo: señal de alerta temprana de incremento del riesgo
MTTD (Mean Time to Detect)	Tiempo medio desde el inicio de un incidente hasta su detección
MTTR (Mean Time to Respond)	Tiempo medio desde la detección de un incidente hasta su contención efectiva

MFA (Multi-Factor Authentication)	Autenticación Multifactor: requiere dos o más factores de verificación
NIS2	Directiva UE 2022/2555 sobre medidas para un alto nivel común de ciberseguridad en la UE
PAM (Privileged Access Management)	Gestión de acceso privilegiado: control de cuentas con permisos elevados
PQC (Post-Quantum Cryptography)	Criptografía resistente a ataques de computadoras cuánticas
RPO (Recovery Point Objective)	Cantidad máxima de datos que una organización puede permitirse perder (ventana temporal)
ROSI (Return on Security Investment)	Retorno de la inversión en seguridad: (pérdida esperada reducida – coste del control) / coste del control
RTO (Recovery Time Objective)	Tiempo máximo tolerable de interrupción antes de que el negocio sufra daño inaceptable
SBOM (Software Bill of Materials)	Inventario exhaustivo de los componentes de software de una aplicación
SLE (Single Loss Expectancy)	Pérdida financiera esperada por una sola ocurrencia de un evento de pérdida
TLPT (Threat-Led Penetration Testing)	Pruebas de intrusión basadas en inteligencia de amenazas reales, requeridas por DORA
TPRM (Third-Party Risk Management)	Gestión del riesgo de terceros: evaluación y monitorización de proveedores y socios
TtE (Time-to-Exploit)	Tiempo desde la divulgación pública de una vulnerabilidad hasta su explotación activa
Zero Trust	Arquitectura de seguridad que asume que ningún actor, interno o externo, es confiable por defecto